TASK 1: SOC

1. SOC FUNDAMENTALS AND OPERATIONS

1.1 Purpose of a Security Operations Center (SOC)

A SOC—usually pronounced "sock" and sometimes called an information security operations center, or ISOC—is an in-house or outsourced team of IT security professionals dedicated to monitoring an organization's entire IT infrastructure 24x7. Its mission is to detect, analyze and respond to security incidents in real-time. This orchestration of cybersecurity functions allows the SOC team to maintain vigilance over the organization's networks, systems and applications and ensures a proactive defense posture against cyber threats [1].

Key Objectives:

- Proactive Threat Detection: Identifying potential threats before they cause harm by continuously analyzing system and network activities.
- Incident Response: Investigating and mitigating security incidents in a timely and efficient manner.
- Continuous Monitoring: Ensuring 24/7 monitoring of systems, applications, and network infrastructure to detect anomalies.

1.2 SOC Team Roles

- Tier 1 – SOC Analyst (Level 1): Tier 1 analysts are mainly responsible for collecting raw data as well as reviewing alarms and alerts. They need to confirm, determine or adjust the criticality of alerts and enrich them with relevant data. For every alert, the triage specialist has to identify whether it's justified or a false positive, as alert fatigue is a real issue. An additional responsibility at this level is identifying other high-risk events and potential incidents [2].
- Tier 2 – SOC Analyst (Level 2 / Incident Responder): At the tier 2 level, analysts review the higher-priority security incidents escalated by triage specialists and do a more in-depth assessment using threat intelligence (indicators of compromise, updated rules, etc.). They need to understand the scope of an attack and be aware of

the affected systems. The raw attack telemetry data collected at tier 1 is transformed into actionable threat intelligence at this second tier. Incident responders are responsible for designing and implementing strategies to contain and recover from an incident.

- Tier 3 – Threat Hunter / Advanced Analyst: Tier 3 analysts are the most experienced workforce in a SOC. They handle major incidents escalated to them by the incident responders. They also perform or at least supervise vulnerability assessments and penetration tests to identify possible attack vectors. Their most important responsibility is to proactively identify possible threats, security gaps and vulnerabilities that might be unknown. They should also recommend ways to optimize the deployed security monitoring tools as they gain reasonable knowledge about a possible threat to the systems [3].
- SOC Manager: SOC managers supervise the security operations team. They provide technical guidance if needed, but most importantly, they are in charge of adequately managing the team. This includes hiring, training and evaluating team members; creating processes; assessing incident reports; and developing and implementing necessary crisis communication plans. They also oversee the financial aspects of a SOC, support security audits, and report to the chief information security officer (CISO) or a respective top-level management position.

1.3 Key SOC Functions

- Identify – Identify an alert as potentially malicious and open an incident.
- Investigate – Investigate the root cause and impact of the incident.
- Mitigate – Recommend mitigation options to isolate and remove a threat.
- Continuous Improvement – Constantly adapt to process, visibility, and technology to improve in real time as incidents occur.

2. SOC FRAMEWORKS

2.1 National Institute of Standards and Technology (NIST) Cybersecurity Framework

The Cybersecurity Framework (CSF) 2.0 is designed to help organizations of all sizes and sectors — including industry, government, academia, and nonprofit — to manage and reduce their cybersecurity risks. It is useful regardless of the maturity level and technical sophistication of an organization's cybersecurity programs. Nevertheless, the CSF does not embrace a one-size-fitsall approach. Each organization has both common and unique risks, as well as varying risk appetites and tolerances, specific missions, and objectives to achieve those missions. By necessity, the way organizations implement the CSF will vary [4]. Ideally, the CSF will be used to address cybersecurity risks alongside other risks of the enterprise, including those that are financial, privacy, supply chain, reputational, technological, or physical in nature.

2.2 MITRE ATT&CK Framework

The MITRE ATT&CK framework is a globally accessible knowledge base of adversary behavior, maintained by MITRE Corporation and grounded in real-world observations. It organizes cyberattack techniques by tactics — each representing a stage in an adversary's objective, such as Initial Access, Privilege Escalation, or Exfiltration. Each technique is mapped to procedures, detection opportunities, and mitigations. ATT&CK allows defenders to model threats based on how adversaries operate post-compromise rather than focusing solely on signatures or indicators. The framework supports cyber threat intelligence analysis, red teaming, defensive gap assessments, and control validation across enterprise, cloud, mobile, and ICS environments [5].

3. TOOLS USED IN SOC

3.1 SIEM (Security Information and Event Management) Tools

SIEM, which stands for Security Information and Event Management, is a cybersecurity solution that correlates log and event data from systems across an IT environment. SIEMs combine two critical functions, Security Information Management (SIM) and Security Event Management (SEM), providing organizations with the following advantages:

- Enhanced threat detection and response

- Improved incident investigation with detailed log data
- Simplified regulatory compliance
- Centralized visibility into network security

Implemented as software, hardware, or managed services, SIEM systems are central to Security operation Centres (SOCs), which detect, investigate, and respond to security incidents. Example: Splunk, ELK Slack, IBM QRadar.

3.2 SOAR (Security Orchestration, Automation, and Response) Tools

Security orchestration, automation and response (SOAR) technology helps coordinate, execute and automate tasks between various people and tools all within a single platform. This allows organizations to not only quickly respond to cybersecurity attacks but also observe, understand and prevent future incidents, thus improving their overall security posture. A comprehensive SOAR product, as defined by Gartner, is designed to operate under three primary software capabilities: threat and vulnerability management, security incident response, and security operations automation. Threat and vulnerability management (orchestration) covers technologies that help amend cyberthreats, while security operations automation (automation) relates to the technologies that enable automation and orchestration within operations. Example: Splunk Phantom

4. SECURITY MONITORING BASICS

4.1 Objectives of Security Monitoring:

The main goal of security monitoring is to detect, analyze, and respond to security threats and incidents in real-time to protect an organization's information assets, networks, and systems. It involves continuously monitoring for suspicious activities, vulnerabilities, and potential breaches to ensure the confidentiality, integrity, and availability of data. For example, security monitoring tools might detect unusual network traffic patterns that could indicate a distributed denial-of-service (DDoS) attack, or identify unauthorized access attempts to

sensitive databases. By responding quickly to such threats, organizations can minimize damage and prevent further compromise.

4.2 Tools Used in Security Monitoring

- SIEM (Security Information and Event Management) Tools**:** It is used to collect, correlate, and analyze logs from multiple sources in real time. It helps in detecting and responding to security incidents. Example: Splunk, Elastic SIEM
- Network Traffic Analyzers: There are some tools used to capture and analyze network packets for identifying suspicious activities. Example: Wireshark

4.3 Key Metrics in Security Monitoring

- False Positives: Alerts that incorrectly indicate a threat when no actual threat exists.
- False Negatives: Failure to detect an actual security threat.
- Mean Time to Detect (MTTD): The average time taken to identify a security incident after it occurs.

4.4 Learning Approach

To develop a strong understanding of security monitoring, it is essential to adopt a practical and hands-on learning approach. A lab environment can be set up using open-source tools such as Elastic SIEM (ELK Stack) to simulate real-world monitoring scenarios. Learners should focus on collecting and analyzing system and network logs to identify suspicious patterns and anomalies. Tools like Wireshark can be used to perform detailed packet-level analysis of network traffic. Additionally, practicing with pre-recorded attack datasets such as Boss of the SOC (BOTS) dataset helps in understanding real attack behaviors and improving investigation skills. Simulating cyberattack scenarios and evaluating detection performance using metrics like false positives, false negatives, and Mean Time to Detect (MTTD) further enhances practical knowledge and efficiency in security monitoring.

5. LOG MANAGEMENT FUNDAMENTALS

5.1 Overview and log Lifecycle

Log management refers to the process of collecting, storing, and analyzing log data generated by various systems and applications. It plays a critical role in security monitoring, troubleshooting, and compliance. The log lifecycle consists of the following stages:

- Collection: Gathering logs from multiple sources such as servers, applications, and network devices.
- Normalization: Converting logs into a standardized format to ensure consistency and ease of analysis.
- Storage: Storing logs securely for future reference and investigation.
- Retention: Maintaining logs for a defined period based on organizational policies or compliance requirements.
- Analysis: Examining logs to detect anomalies, security threats, or system issues.

5.2 Common Types of Logs

- Windows Event Logs**:** Logs generated by Windows systems that record system, security, and application events.
- Syslog**:** A standard logging format used by Linux/Unix systems and network devices.
- HTTP Server Logs: Logs generated by web servers (e.g., Apache, Nginx) that capture client requests and server responses.

5.3 Learning Approach

To understand log management effectively, a lab environment should be set up where tools like Fluentd or Logstash are used to collect logs from systems. The collected logs should then be normalized into a standard format such as JSON or CEF for consistency. Learners should also practice querying logs using SQL-like query languages such as KQL to extract meaningful insights and detect suspicious activities.

6. SECURITY TOOLS

6.1 Introduction

Security tools are essential components of modern cybersecurity operations. They help in detecting, analyzing, and responding to security threats across networks, endpoints, and systems. This section provides an overview of commonly used tools and their practical implementation.

6.2 Key Security Tools

- SIEM (Security Information and Event Management): It collects and correlates logs from multiple sources, provides real-time monitoring and alerting and helps in incident investigation and compliance.
- EDR (Endpoint Detection and Response): It monitors endpoint activities, detects malware and suspicious behavior and provides response mechanisms like isolation.
- IDS/IPS (Intrusion Detection/Prevention Systems): It detects malicious network traffic
  generates alerts for suspicious activity and can block attacks in IPS mode.
- Vulnerability Scanners: Identifies security vulnerabilities in systems provides risk scores (CVSS) Suggests remediation steps.

6.3 Learning Approach

To gain hands-on experience with security tools, free and open-source platforms can be utilized. Tools like Splunk Free and Wazuh provide practical exposure to log analysis and threat detection. Intrusion detection systems such as Snort can be configured in a sandbox environment to detect simulated attacks. Vulnerability scanning can be practiced using Nessus against intentionally vulnerable machines like Metasploitable. Additionally, tools like Osquery can be used to monitor system-level activities such as running processes.

7. BASIC SECURITY CONCEPTS

7.1 CIA Triad

Basic security concepts form the foundation of cybersecurity practices. Understanding these concepts helps in identifying risks, protecting systems, and designing secure architectures. The CIA Triad is a fundamental model used to guide information security policies and practices.

- Confidentiality: Ensures that sensitive information is accessible only to authorized users, prevents unauthorized access to data. Example: Encryption of data, Use of strong passwords, Access control mechanisms.
- Integrity: Ensures that data remains accurate, consistent, and unaltered, protects data from unauthorized modification. Example: Hashing techniques, Digital signatures, File integrity monitoring.
- Availability: Ensures that systems and data are accessible when needed, protects against disruptions such as system failures or attacks. Example: Backup systems, Redundancy mechanisms, Protection against DDoS attacks.

7.2 Threat, Vulnerability, and Risk

A cyber threat is a malicious act that seeks to steal or damage data or discompose the digital network or system. Threats can also be defined as the possibility of a successful cyberattack to get access to the sensitive data of a system unethically. Types of Threat: Intentional (Malware, phishing, and accessing someone's account illegally), Unintentional (forgetting to update the firewall or the anti-virus could make the system more vulnerable), Natural (Natural disasters can also damage the data).

In cybersecurity, a vulnerability is a flaw in a system's design, security procedures, internal controls, etc., that can be exploited by cybercriminals. Types of Vulnerability: Network (Network vulnerability is caused when there are some flaws in the network's hardware or software), Operating system (When an operating system designer designs an operating system with a policy that grants every program/user to have full access to the computer, it allows viruses and malware to make changes on behalf of the administrator), Human (Users'

negligence can cause vulnerabilities in the system), Process (Specific process control can also cause vulnerabilities in the system).

Cyber risk is a potential consequence of the loss or damage of assets or data caused by a cyber threat. Risk can never be completely removed, but it can be managed to a level that satisfies an organization's tolerance for risk. So, our target is not to have a risk-free system, but to keep the risk as low as possible. Cyber risks can be defined with this simple formula- Risk = Threat + Vulnerability. Cyber risks are generally determined by examining the threat actor and type of vulnerabilities that the system has. Types of Risks: External (cyberattacks, phishing, ransomware, DDoS attacks), Internal (Internal cyber risks come from insiders).

7.3 Defense-in-Depth

A Defense-in-Depth strategy, aka a security-in-depth strategy, refers to a cybersecurity approach that uses multiple layers of security for holistic protection. A layered defense helps security organizations reduce vulnerabilities, contain threats, and mitigate risk. In simple terms, with a defense-in-depth approach, if a bad actor breaches one layer of defense, they might be contained by the next layer of defense. The defense-in-depth concept was originally conceived by the U.S. National Security Agency (NSA) and takes its name from a common military strategy. (A defense-in-depth cybersecurity strategy is also sometimes referred to as a castle approach because it is similar to the layered defenses of a medieval castle with moats, drawbridges, towers, etc.). Examples of Layers: Firewalls, IDS, Antivirus software, Access control, etc.

7.4 Zero Trust Model

Zero trust operates on the principle of “never trust, always verify” rather than granting implicit trust to all users inside a network. This granular security approach helps address the cybersecurity risks posed by remote workers, hybrid cloud services, personally owned devices and other elements of today’s corporate networks. Every access request must be authenticated and authorized, regardless of whether it originates from inside or outside the traditional network perimeter. This continuous verification process ensures that a

compromised entity cannot move freely throughout the network. It offers several key benefits in the face of evolving cybersecurity threats:

- Enhanced Security
- Protection Against Data Breaches
- Improved Visibility and Monitoring
- Reduced Risk of Advanced Persistent Threats (APTs)
- Scalability
- Support for Remote Work and Cloud Environments
- Addresses Compliance Requirements

7.5 Learning Approach

To effectively understand basic security concepts, flashcards can be used to memorize key terminologies and definitions, using tools such as Anki. Additionally, studying real-world case studies like the Equifax Data Breach helps in understanding how security failures occur in practice. This particular breach highlights the consequences of failing to patch known vulnerabilities, emphasizing the importance of timely updates and proper risk management.

8. SECURITY OPERATIONS WORKFLOW

8.1 Stages of Security Operations Workflow

Security operations workflow defines the structured process followed by a Security Operations Center (SOC) to detect, analyze, and respond to cybersecurity incidents. It ensures efficient handling of threats and minimizes potential damage.

- Detection: The first stage where potential security incidents are identified. Alerts are generated using tools such as SIEM and EDR. Example: Suspicious login attempts, Malware detection alerts, unusual network traffic.
- Triage: Involves analyzing and prioritizing alerts based on severity and impact. Helps in distinguishing between false positives and real threats. Example: Alert validation, Severity classification (low, medium, high), Escalation.
- Investigation: Detailed analysis of the incident to determine its root cause. Involves correlating logs and identifying Indicators of Compromise (IOCs). Key Activities: Log correlation, Threat intelligence lookup, IOC identification
- Response: Final stage where action is taken to mitigate the threat. Key Actions: Containment: Isolate affected systems, Eradication: Remove malware or threat, Recovery: Restore systems to normal operation.

8.2 Learning and Implementation Approach

To understand the security operations workflow practically, incident response platforms such as TheHive can be used to simulate real-world scenarios. These platforms help in managing alerts, assigning cases, and tracking the response process. Additionally, creating flowcharts for common incidents, such as phishing attacks, helps in visualizing the workflow and improving understanding of each stage.

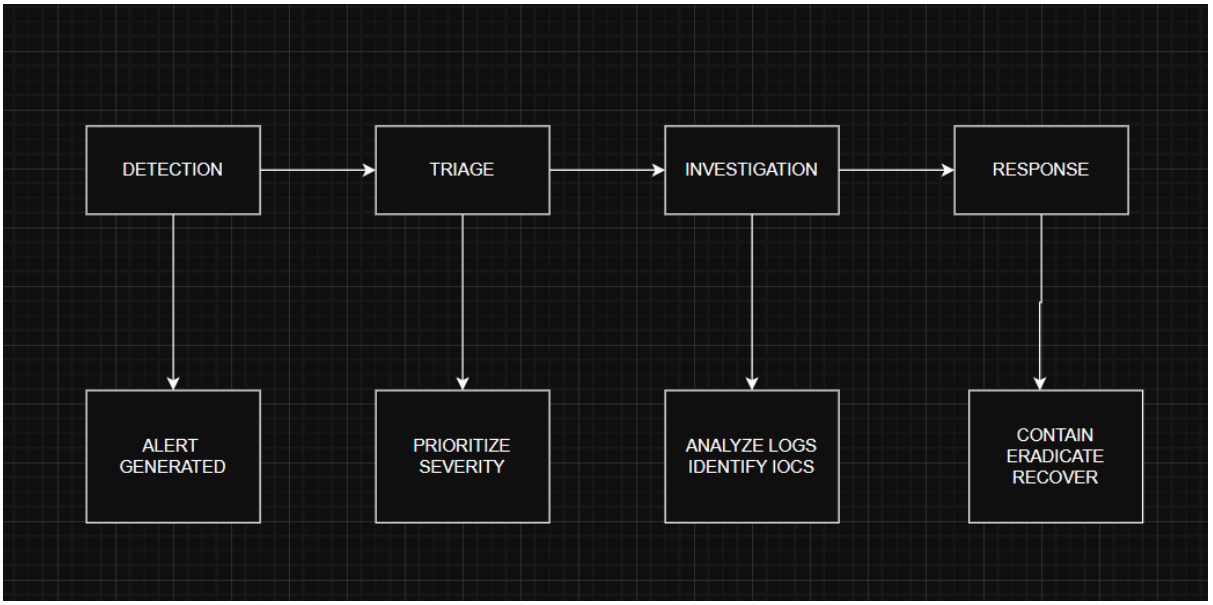

Figure 1: Flowchart of Security Operations Workflow

9. INCIDENT RESPONSE BASICS

9.1 Incident Response Lifecycle

Incident Response (IR) is a structured approach used to identify, manage, and mitigate cybersecurity incidents. The goal of incident response is to minimize damage, reduce recovery time, and prevent future incidents. The lessons learned from IR activities are also used to inform downstream prevention and mitigation strategies, thereby enhancing an organization's overall security posture. The Incident Response process follows a well-defined lifecycle consisting of the following stages:

1. Preparation: Involves setting up tools, policies, and procedures before an incident occurs. Ensures the organization is ready to handle security incidents effectively.
   Activities: Creating incident response plans, Training security teams.
2. Identification: Detecting and confirming whether a security incident has occurred.
   Activities: Monitoring alerts and logs, Validating security incidents.
3. Containment: Limiting the spread and impact of the incident.
   Activities: Short-term containment (Isolate affected systems), Long-term containment (Apply temporary fixes to prevent spread).

4. Eradication: Removing the root cause of the incident from the system.
   Activities: Deleting malware, fixing vulnerabilities, applying security patches.
5. Recovery: Restoring affected systems and services to normal operation.
   Activities: System restoration from backups, monitoring for reinfection, validating system functionality.
6. Lessons learned: Final stage focused on improving future response.
   Activities: Documenting the incident, identifying gaps in security, updating policies and tools.

Example Scenario: Ransomware Attack

Step 1: Preparation

- Backup systems are in place
- Security tools are configured

Step 2: Identification

- Files are encrypted and ransom note appears

Step 3: Containment

- Disconnect infected system from network

Step 4: Eradication

- Remove ransomware and clean the system

Step 5: Recovery

- Restore files from backup

Step 6: Lessons Learned

- Identify how ransomware entered

- Improve email filtering and patching

10.PRACTICAL IMPLEMENTATION

10.1 Log Analysis Practice

Browser activity was analyzed using the BrowsingHistoryView tool. This tool was used to extract and analyze browsing history from the Google Chrome browser. A test URL (http://example.com

) was visited and successfully identified in the browsing history. The tool provided details such as visit time, visit count, browser profile, and URL information. This demonstrates how forensic tools can be used to analyze user activity and detect potentially suspicious or unauthorized browsing behavior.

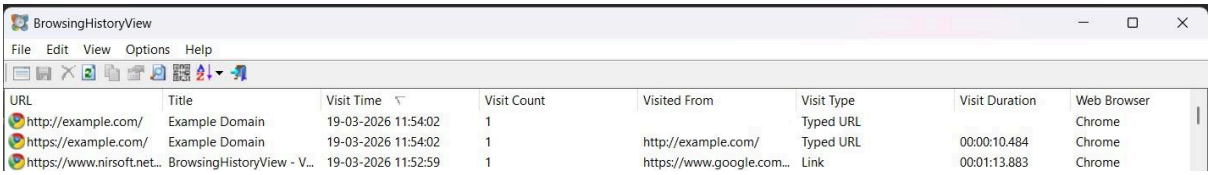

Figure 2: BrowsingHistoryView URLs

10.2 Document Security Events

Security events were documented using a structured format including Date/Time, Source IP, Event ID, Description, and Action Taken.

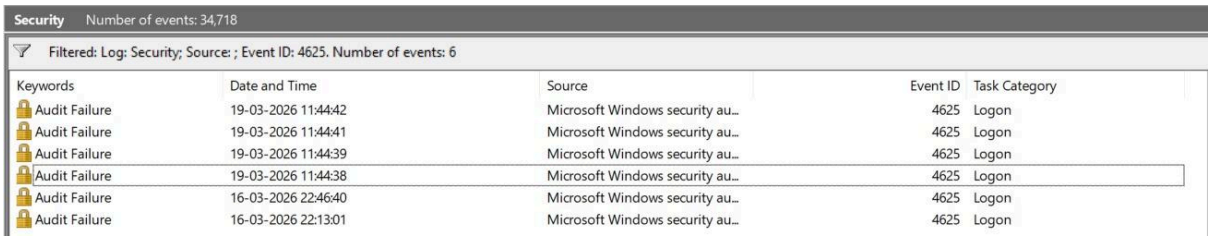

Figure 3: Failed Login Attempts

Date/Time	Source IP	Event ID	Description	Action Taken
19-03-2026 11:44:39	127.0.0.1	4625	6 failed login attempts	Investigated brute-force attack

10.3 Monitoring Dashboards

Monitoring dashboards were explored using Kibana to visualize security data such as top source IPs and frequency of critical events. These dashboards help analysts quickly identify suspicious patterns.

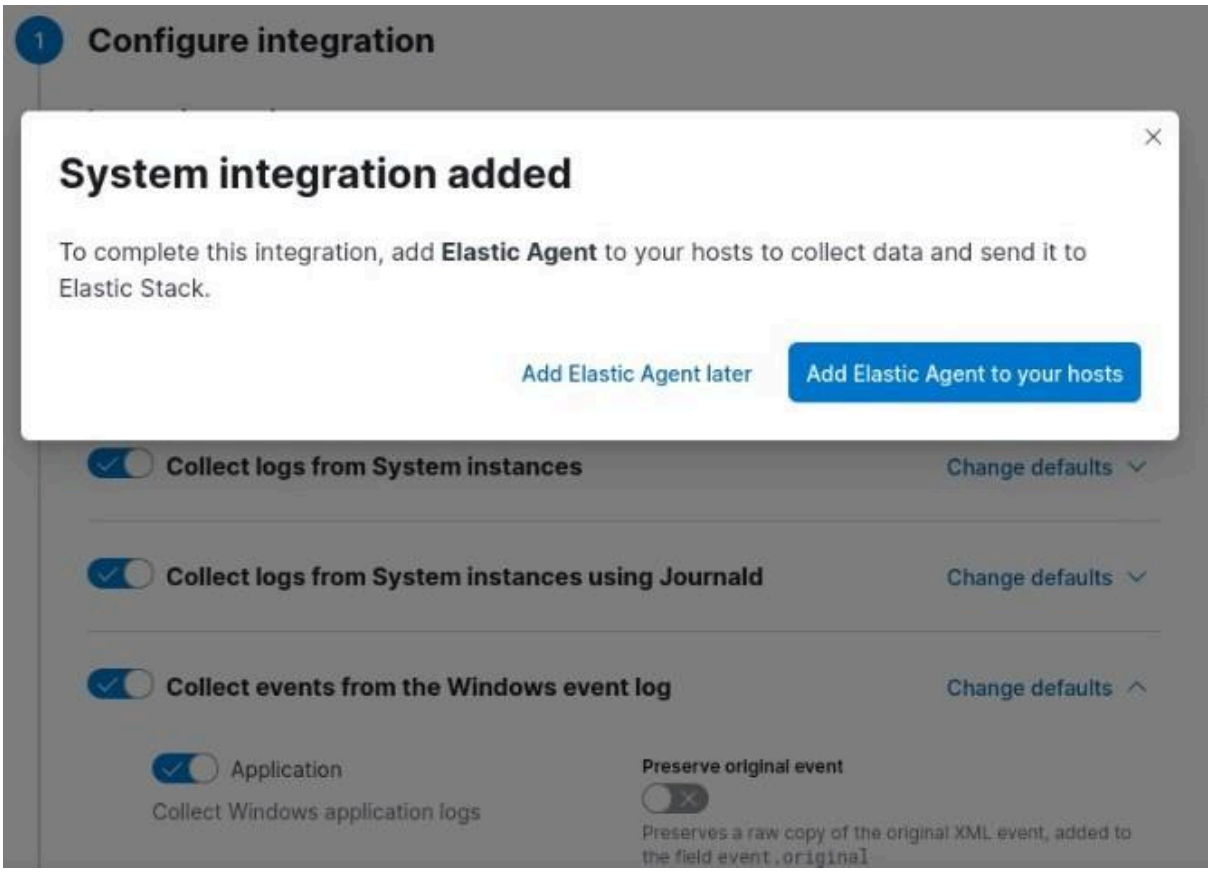

Figure 4: Kibana dashboard

11. DOCUMENTATION STANDARDS

Documentation is a critical component of cybersecurity operations. Proper documentation ensures consistency, accountability, and effective communication during and after security incidents. It also helps in knowledge sharing and improving future response strategies. Types of Security Documentation:

1. Incident Reports: Detailed records of security incidents, include information about the nature, impact, and resolution of the incident. Contents- date and time of incident affected systems, description of the attack, actions taken, final outcome.

2. Runbooks: Step-by-step guides for handling specific types of incidents, help analysts respond quickly and consistently. Examples- malware removal procedure, phishing email response steps.

3. Standard Operating Procedures (SOPs): Formal documents that define standard processes for routine operations, ensure uniformity in security practices. Examples**:** User access control procedures, log monitoring guidelines.

4. Post-Mortem Reports: Created after resolving an incident, focus on analyzing what went wrong and how to improve.

Contents: Root cause analysis, timeline of events, lessons learned, preventive measures.

Example: Mock Incident Report (DDoS Attack)

Incident Title: Distributed Denial of Service (DDoS) Attack

1. Date & Time: 10 March 2026, 14:30 IST.
2. Description: The web server experienced a sudden surge in traffic, causing service disruption.
3. Affected system: Company website server.
4. Detection method: Alerts from monitoring tools indicating abnormal traffic spikes.
5. Response action: Blocked suspicious IP addresses, enabled rate limiting, activated firewall protection.
6. Impact: Website downtime for 30 minutes.
7. Resolution: Traffic normalized after mitigation measures.
8. Lessons learned: Need for stronger DDoS protection, implementation of automated traffic filtering.